

DIKWP Ultimate Confidential Exchange System

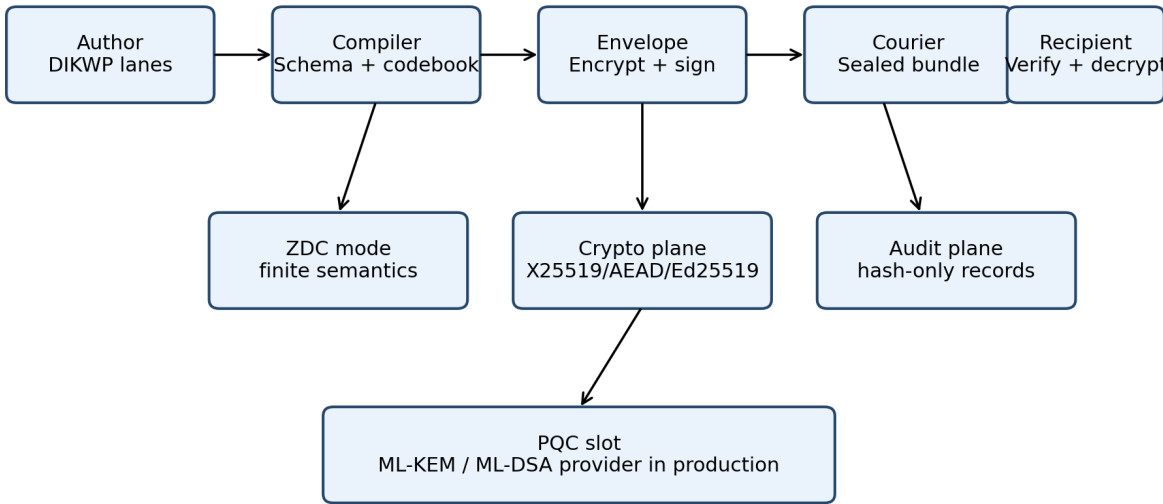
终极 DIKWP 保密交流系统：可运行交付、边界证明与操作手册

交付定位

本报告随附可运行系统包。系统目标不是制造暗通信，而是把保密交流压成：身份可验证、内容最小披露、语义可控、密文不可读、审计不泄密、暗信道边界可声明的高保证接口。

项目	内容
系统名	DIKWP Confidential Exchange System (DCE)
版本	v1.0.0 local-first reference implementation
核心模式	ZDC 有限语义模式 + memo 加密备忘模式
密码原语	X25519, HKDF-SHA256, ChaCha20-Poly1305, Ed25519
交付物	ZIP 系统包 + DOCX/PDF 报告
测试状态	5 个本地单元测试通过，demo 流程跑通

DIKWP Confidential Exchange - Layered Architecture



1. P-意图合同与一句话本质

P-意图合同

从“希望有一个终极保密交流系统”推进到“获得一个可运行、可审计、可扩展、边界诚实的 DIKWP 保密交流系统”；成功判据是：能本地生成身份、编译 DIKWP 消息、加密、签名、验证、解密、出审计记录，并明确知道哪些安全结论成立、哪些不成立。

一句话本质

终极保密交流不是“什么都能秘密说”，而是把可交流内容先压成声明过的 DIKWP 语义，再用成熟密码封装，并用审计和角色分离防止保密权被滥用。

2. 关键词语义注册

词项	D/I/K/W/P 注册
保密交流	D: 只有授权主体能读的交流实例；I: 区别于公开发布、暗信道逃逸和无认证传输；K: 完整语义是“机密性+完整性+身份+目的绑定”；W: 偏好最小披露与合法授权；P: 从裸信息流推进到受控可信交换。
终极	D: 在现实约束下尽可能强的系统；I: 不是神话式绝对安全；K: 强保证必须绑定边界、TCB 和操作纪律；W: 偏好可验证胜过口号；P: 从“好像安全”推进到“可审计地安全”。
暗信道	D: 通过未声明自由度传递额外信息；I: 区别于声明语义本身；K: 信道容量来自格式、时序、长度、随机性、选择空间；W: 排斥未授权信息外流；P: 从自由流动推进到声明、压缩、固定、审计。
DIKWP	D: Data/Information/Knowledge/Wisdom/Purpose 五类语义；I: 区别于自由文本和单一标签；K: 让内容按事实、差异、结论、价值、目的分层；W: 偏好理解可回放；P: 从混杂表达推进到可验证表达。

3. 系统总架构

DCE 分成五个平面：语义平面、披露平面、密码平面、审计平面、PQC 扩展平面。语义平面负责“不多说”；密码平面负责“别人看不见”；审计平面负责“以后能追溯”；PQC 扩展平面负责“未来能迁移”。

系统提供两种模式。ZDC 模式只允许有限 codebook 语义，适合高风险治理、机密决策、保密汇报；memo 模式允许自由文本，但只保证加密认证，不声称绝对消灭暗信道。

模式/平面	作用	边界
ZDC	有限 codebook、无自由文本、固定封包、零填充校验	最高保证；表达受限
Memo	自由文本进入 D/I/K/W/P 五个栏位后加密签名	表达强；暗信道控制弱
Audit	只输出 hash、身份指纹、目的、算法套件、控制声明	可治理；不泄露正文
PQC slot	预留 ML-KEM / ML-DSA 接口	当前本地 demo 未内置 PQC 实现

4. 密码与标准选择

本地参考实现使用成熟库提供的 X25519、HKDF-SHA256、ChaCha20-Poly1305 和 Ed25519。它不是自造密码。报告同时将生产级后量子迁移写进接口：NIST 已发布 ML-KEM 作为密钥封装标准、ML-DSA 作为数字签名标准；HPKE 的标准化思路可作为未来 envelope encryption 的互操作参考；长期对话可吸收 Signal Double Ratchet 思路。

部件	当前实现	生产增强
密钥协商	X25519 ephemeral-static	本地可运行；生产可升级 hybrid ML-KEM
密钥派生	HKDF-SHA256	绑定身份、目的、临时公钥和 transcript
加密认证	ChaCha20-Poly1305	AEAD，认证加密
签名	Ed25519	发送方身份认证；生产可加 ML-DSA/SLH-DSA
封包	固定大小 frame + zero padding check	降低长度侧信道，拒绝非零填充

5. “绝对”的真相边界

What can be guaranteed, and what cannot

Scoped guarantee	Residual reality
✓ Canonical DIKWP payload ✓ Finite ZDC codebook ✓ Fixed-size sealed frame ✓ Zero padding check ✓ Sender signature ✓ Hash-only audit	! Compromised endpoint ! Coerced user ! Timing / volume leakage ! Recipient disclosure ! Allowed semantics as channel ! Unvalidated PQC provider risk

Truth condition: absolute secrecy is only meaningful inside a stated boundary.

必须说死

不存在对恶意端点、被胁迫用户、收件人泄密、发送时机、通信存在性、语义选择本身都同时“绝对消灭暗信道”的纯软件系统。DCE 的绝对性只在受控边界内成立：可信 compiler + ZDC 有限语义 + 规范化 payload + 固定大小封包 + 零填充校验 + 签名/审计。

6. 已实际交付的系统部件

目录	内容
src/dikwp_confidential_exchange/	核心 Python 包：identity、dikwp、crypto、audit、cli、api
codebooks/	有限语义 codebook：DIKWP_SECURE_EXCHANGE_V1
examples/	zdc_message.yaml 与 memo_message.yaml 示例
tests/	往返加解密、篡改失败、ZDC 拒绝自由文本、固定密文大小、审计记录
docs/	威胁模型、架构、操作手册、安全声明、角色分离、PQC 迁移
scripts/	demo.sh 与 hardening_check.py
policies/	分级策略：PUBLIC/INTERNAL/CONFIDENTIAL/SECRET/TOP_SECRET

7. 操作流程

1. 在干净机器上生成 Alice/Bob 身份，并线下核对 public fingerprint。
2. 用 codebook 将消息编译为 DIKWP payload。SECRET 以上默认只准 ZDC 模式。
3. 发送方用自己的 private identity 签名，并用收件方 public identity 加密。
4. 收件方先验证发送方签名和 fingerprint，再解密。
5. 审计方只拿 hash-only audit record，不拿正文。
6. 若验证失败、padding 非零、目的不匹配、fingerprint 不匹配，立即 freeze。

最短 demo 命令

```
cd dikwp_confidential_exchange_system && ./scripts/demo.sh
```

该脚本会自动生成 demo 身份、编译 ZDC 消息、加密、验证、解密并输出审计记录。

8. 安全审计与治理用法

场景	推荐模式	级别	控制
普通秘密交流	memo 模式	CONFIDENTIAL 及以下	仍需身份核验和密钥保护
高风险 AI 治理汇报	ZDC 模式	SECRET	二人编译、hash-only audit
董事会/监管前沟通	ZDC + memo 附件分离	SECRET/TOP_SECRET	核心结论 ZDC，细节另封附件
事故应急	P_EMERGENCY_FREEZE code	SECRET	冻结、审计、轮换密钥

9. 下一步生产化路线

阶段	动作	目标
第 1 周	接入真实组织身份、固定 codebook、建立密钥仪式	能用
第 2-4 周	接入 HSM/KMS、对象存储、SSO、审批流、日志系统	可管
第 2 月	引入 PQC provider、形式化策略、红队测试、第三方审计	可信
第 3 月	做成治理培训/测评产品中的保密交付模块	可卖

10. SemProof / ExtProof / Residual

SemProof

若保密交流要服务 DIKWP，而不是沦为“自由文本加密”，则必须先控制语义自由度，再控制表示自由度，再控制传输自由度。ZDC 模式把 D/I/K/W/P 变成有限 codebook；固定 frame 与零填充把表示层自由度压低；签名与审计把身份和责任接回治理链。

ExtProof

密码原语层依赖成熟标准与库；后量子层引用 NIST FIPS 203/204 的正式标准方向，但本地 demo 未内置正式 PQC provider；“零暗信道”仅在可信 compiler 与 ZDC 边界内可成立。

Residual

仍未解决端点妥协、时序流量分析、被胁迫披露、恶意用户利用允许语义选择编码、以及未验证 PQC 库的供应链问题。生产部署必须通过组织流程、硬件隔离和审计补足。

11. 参考来源

NIST FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM).

NIST FIPS 204: Module-Lattice-Based Digital Signature Standard (ML-DSA).

RFC 9180: Hybrid Public Key Encryption.

Signal Double Ratchet and X3DH specifications.

本系统随附源码与本地测试结果。